

II.C.8 Physical Security

Action Summary

Management should implement appropriate preventive, detective, and corrective controls for physical security.

Physical access and damage or destruction to physical components can impair the confidentiality, integrity, and availability of information. Management should implement appropriate preventive, detective, and corrective controls for mitigating the risks inherent to those physical security zones.

A data center houses an institution's most important information system components. When selecting a site for a data center, one major objective should be to limit the risk of exposure from internal and external threats, including, where possible, environmental threats inherent to physical locations (e.g., hurricanes, earthquakes, and blizzards). The selection process should include reviewing the surrounding area to determine whether it is relatively safe from exposure to fire, flood, explosion, or similar environmental hazards. Guards, fences, barriers, surveillance equipment, or other devices can deter intruders. Because access to key information systems' hardware and software should be limited, appropriate physical controls should be in place. Additionally, the location should not be identified or advertised by signage or other indicators.

Detection devices, when applicable, should be used to prevent theft and safeguard the equipment. The devices should provide continuous coverage. Detection devices have two purposes—to send alarms when responses are necessary and to support subsequent forensics. Alarms are useful only when response will occur. Some detection devices include the following:

- Switches that activate alarms when electrical circuits are broken.
- Light and laser beams, ultraviolet beams, sound, or vibration detectors that are invisible to intruders, and ultrasonic or radar devices that detect movement.
- Closed-circuit television (CCTV) that provides visual observation and records intrusions.

A combination of fire suppression, smoke alarms, raised flooring, and heat and moisture sensors should address risks from environmental threats (e.g., fire, flood, and excessive heat). Environmental threat monitoring should be continuous, and responses should occur when alarms activate.

Physical security devices frequently need preventive maintenance to function properly. The institution should be able to provide maintenance logs to demonstrate that physical security devices are regularly maintained. Periodic testing provides assurance that the devices are operating correctly.

The institution should have policies governing the duties and responsibilities of security guards. Employees who access secured areas should have proper identification and authorization to enter the areas. All non-employees should provide identification to a security guard before obtaining

access. Security guards should be trained to restrict the removal of technology assets from the premises and to record the identity of anyone attempting to remove those assets. Management should implement a specific and formal authorization process for the removal of hardware and software from the premises.

Access should be restricted to the following equipment or areas:

- Operations centers (e.g., data center operations, security operations center, and network operations center) or server rooms; uninterruptible power supplies and backup generators.
- Funds transfer and automated clearinghouse routers.
- Telecommunications equipment.
- Media libraries.
- Equipment removed from the network and awaiting disposal.
- Spare or backup devices.

II.C.9 Network Controls

Action Summary

Management should secure access to computer networks through multiple layers of access controls by doing the following:

- Establishing zones (e.g., trusted and untrusted) according to the risk profile and criticality of assets contained within the zones and appropriate access requirements within and between each security zone.
- Maintaining accurate network diagrams and data flow charts.
- Implementing appropriate controls over wired and wireless networks.

Networks should be protected by a secure boundary, identifying “trusted” and “untrusted” zones. Internal zones, typically trusted, should segregate various components into distinct areas, each with the level of controls appropriate to the content and function of the assets within the zone. The institution’s trusted network should be protected through appropriate configuration and patch management, privileged access controls, segregation of duties, implementation of effective security policies, and use of perimeter devices and systems to prevent and detect unauthorized access. Tools used to enforce and detect perimeter protection include routers, firewalls, intrusion detection systems (IDS) and intrusion prevention systems, proxies, gateways, jump boxes,²⁵ demilitarized zones, virtual private networks (VPN), virtual LANs (VLAN), log monitoring and network traffic inspecting systems, data loss prevention (DLP) systems, and access control lists.

The trusted network should be further segregated into internal layers, including production, staging, and development environments. Within those environments, management should

²⁵ A jump box, or jump server, provides administrators with access to or control of other servers or devices in the network. Because of this capability, additional security measures should be implemented.

consider segregating sensitive traffic, by using Voice Over Internet Protocol²⁶ (VOIP) and network management (such as virtualization infrastructure that carries server boot images between storage devices and hosts). Each zone should have a security policy appropriate to its use, ensuring that zone restrictions are defined by risk, sensitivity of data, user roles, and appropriate access to application systems. Access to zones should be controlled according to the principle of least privilege and segregation of duties. To ensure appropriate network security, management should maintain accurate network and data flow diagrams, and store them securely, providing access only to essential personnel. These diagrams should identify hardware, software, and network components, internal and external connections, and types of information passed between systems to facilitate the development of a defense-in-depth security architecture.

II.C.9(a) *Wireless Network Considerations*

A wireless LAN (WLAN) is a medium of network connectivity, supported by radio wave transmissions that provides more convenient network access to employees or devices that need flexibility to connect to multiple locations within the institution's facilities. Because the user is not physically connected to the network and the wireless signal is broadcast and available to others, wireless networks are inherently less secure than wired networks and require additional scrutiny, controls, and oversight. Wireless access points are the devices that broadcast the radio wave signals and should be physically secure to prevent compromise and securely configured to provide the same level of control as a wired connection. Wireless gateways can allow management to implement more complex access controls, including advanced identity management capabilities and services to detect and remediate malicious software.

Policies should prohibit installation of wireless access points and gateways without approval and formal inclusion in the hardware inventory. Network monitoring systems should be configured to detect the addition of new devices. Alternatively, network access control (NAC) systems could prevent the recognition of any unauthorized device.²⁷ Management should consider limiting the WLAN signal to authorized areas, within the boundaries of the institution, if feasible. Management should use an industry-accepted level of encryption with strength commensurate with the institution's risk profile on the institution's wireless networks.

Malicious insiders and attackers may also set up rogue or unauthorized wireless access points and trick employees into connecting. Such access points allow attackers to monitor employee activities. The institution should scan the network regularly to detect rogue access points and consider implementing NAC systems to prevent the successful connection of unauthorized devices.

²⁶ VOIP is the transmission of voice telephone conversations using the Internet or IP networks.

²⁷ A NAC system typically provides an IP address only after validating that the newly connected device is authorized, by means of some identification (such as a computer's physical address—MAC address—or certificate) or pre-installed client software.

The institution may provide guests with access to a wired or wireless network. The guest network generally is used to provide access to the Internet and should be configured to prevent access to any portion of the production network.

Institutions often provide remote network connectivity for employees or third-party service providers²⁸ who are not located within or around the institution's facilities. This connectivity presents operational advantages, but steps should be taken to ensure that the connection is encrypted and secured. VPN connections should be used for both broadband networks and wireless air card connections to isolate and encrypt remote traffic to institution networks. IP geolocation information may not always be available when using broadband networks, which can limit the effectiveness of monitoring. Therefore, management should consider implementing compensating controls, such as restricting access to network resources.

II.C.10 Change Management Within the IT Environment

Action Summary

Management should have a process to introduce changes to the environment in a controlled manner. Changes to the IT environment include the following:

- Configuration management of IT systems and applications.
- Hardening of systems and applications.
- Use of standard builds.
- Patch management.

The IT environment consists of operating systems,²⁹ middleware,³⁰ applications, file systems, and communications protocols. The institution should have an effective process to introduce application and system changes, including hardware, software, and network devices, into the IT environment. The process for introducing software should encompass securely developing, implementing, and testing changes to both internally developed and acquired software.

Application and system control considerations for introducing changes to the IT environment before implementation should include the following:

- Developing procedures to guide the process of introducing changes to the environment.
- Clearly defining requirements for changes.
- Restricting changes to authorized users.

²⁸ In some cases, the institution provides remote access via VPN to a third-party service provider. Controls over third-party access should be commensurate with the sensitivity and criticality of the system and information accessed.

²⁹ An operating system is fundamental software that supports and manages software applications, allocates system resources, provides access and security controls, maintains file systems, and manages communications between end users and hardware devices.

³⁰ Middleware is software that connects two or more software components or applications.

- Reviewing the impact that changes have on security controls.
- Identifying all system components affected by the changes.
- Developing test scripts and implementation plans.
- Performing necessary tests of all changes to the environment (e.g., systems testing, integration testing, functional testing, user acceptance testing, and security testing).
- Defining rollback procedures in the event of unintended or negative consequences with the introduced changes.
- Ensuring the application or system owner has authorized changes in advance.
- Maintaining strict version control of all software updates.
- Validating that new hardware complies with institution policies.
- Ensuring network devices are properly configured and function appropriately within the environment.
- Maintaining an audit trail of all changes.

Refer to the *IT Handbook's* "Development and Acquisition" booklet for more information.

II.C.10(a) Configuration Management

Configuration management is a process to securely maintain the institution's technology by developing expected baselines for tracking, controlling, and managing systems settings. To mitigate information security risk, management should control configurations of systems, applications, and other technology. Effective configuration management relies on policies and procedures to ensure compliance with minimally acceptable system configuration requirements. When information systems change, management should update baselines; confirm security settings; and track, verify, and report configuration items. Configurations should be monitored for unauthorized changes, and misconfigurations should be identified. Management can use automated solutions to help track, manage, and identify necessary corrections.

II.C.10(b) Hardening

Institutions typically use commercial off-the-shelf (COTS) software for operating systems and applications, on such diverse platforms as network infrastructure, servers, desktops, laptops, and mobile devices. COTS systems generally provide more functions than are required for the specific purposes for which they are employed. A default installation of a server operating system may include mail, web, and file-sharing services on a system that does not require those functions. Unnecessary software and services represent a potential security weakness. Their presence increases the potential number of discovered and undiscovered vulnerabilities in the system. Additionally, system administrators may not install patches or monitor the unused software and services to the same degree as they would operational software and services. Protection against those risks begins when the systems are constructed and software installed through a process that is referred to as hardening a system.

Management should consult operating system and software vendor-recommended security controls. When deploying COTS applications and systems, management should harden the resulting applications and systems. Hardening can include the following actions:

- Determining the purpose of the applications and systems and documenting minimum software and hardware requirements and services to be included.
- Installing the minimum hardware, software, and services necessary to meet the requirements using a documented installation procedure.
- Installing necessary patches.
- Installing the most secure and up-to-date versions of applications.
- Configuring privilege and access controls by first denying all, then granting back the minimum necessary to each user (i.e., enforcing the principle of least privilege).
- Configuring security settings as appropriate, enabling allowed activity, and prohibiting non-approved activities.
- Enabling logging.
- Creating cryptographic hashes³¹ of key files.
- Archiving the configuration and checksums³² in secure storage before system deployment.
- Using secure replication procedures for additional, identically configured systems and making configuration changes on a case-by-case basis.
- Changing all default passwords.
- Testing the system to ensure a secure configuration.

Additionally, the systems should be audited periodically to ensure that the hardware, software, and services are authorized and properly configured.

II.C.10(c) *Standard Builds*

Consistency in system configuration makes security easier to implement and maintain. The institution should use standard builds, which allow one documented configuration to be applied to multiple computers in a controlled manner. Some institutions, depending on their size and complexity, may have many standard builds for the different system configurations needed to address various business functions. Through standard builds, an institution simplifies the following activities:

- Creating hardware and software inventories.
- Updating and patching systems.
- Restoring systems in the event of a disaster or outage.
- Investigating anomalous activity.
- Auditing configurations for conformance with the approved configuration.

The institution may not be able to meet all of its requirements from its standard builds. The use of nonstandard builds should be documented and approved by management, with appropriate changes made to patch management and disaster recovery plans.

³¹ A hash is a fixed-length cryptographic output of variables, such as a message, being operated on by a formula or cryptographic algorithm.

³² A checksum is a simple error-detection scheme in which each transmitted message is accompanied by a numerical value based on the number of set bits in the message, which allows the receiver to verify the accuracy of the message.

II.C.10(d) *Patch Management*

Frequently, security vulnerabilities are discovered in operating systems and other software after deployment. Hackers often will attempt to exploit these known vulnerabilities to try to gain access to the institution's systems. Third parties issue patches to address vulnerabilities found on institution systems and applications.³³ Management should implement automated patch management systems and software to ensure all network components (virtual machines, routers, switches, mobile devices, firewalls, etc.) are appropriately updated. In addition, management should use vulnerability scanners periodically to identify vulnerabilities in a timely manner.

As part of the institution's patch management process, management should establish and implement the following:

- A monitoring process that identifies the availability of software patches.
- A process to evaluate the patches against the threat and network environment.
- A prioritization process to determine which patches to apply across classes of computers and applications.
- A process for obtaining, testing, and securely installing patches, including in the institution's virtual environments.
- An exception process, with appropriate documentation, for patches that management decides to delay or not apply.
- A process to ensure that all patches installed in the production environment are also installed in the disaster recovery environment in a timely manner.
- A documentation process to ensure the institution's information assets and technology inventory and disaster recovery plans are updated as appropriate when patches are applied.

The institution should have procedures that include how to implement patches to mitigate risks of changing systems and address systems with unique configurations. Before applying a patch, management should back up the production system. Additionally, management should define appropriate patch windows and, whenever possible, restrict the implementation of patches to defined time frames to minimize business impact or potential down time.

Patches make direct changes to the software and configuration of each system to which they are applied. While patches are necessary and useful, they may have unintended negative consequences, such as introducing new vulnerabilities, reintroducing old vulnerabilities, or degrading system performance. The following actions can help ensure patches do not compromise the security of the institution's systems:

- Obtain the patch from a known, trusted source.
- Verify the integrity of the patch through comparisons of cryptographic hashes to ensure the patch obtained is correct and unaltered.
- Protect and monitor the systems used to distribute patches to ensure only authorized patches are distributed.

³³ If an institution develops or maintains software in-house, management should have a process to update the software with appropriate patches.

- Apply the patch to an isolated test system before installing on the production system to ensure the patch is compatible with other software used on systems, does not alter the system's security posture in unexpected ways (such as altering log settings), and corrects the pertinent vulnerability.
- Test the resulting system to validate the effectiveness of the applied patch.

II.C.11 End-of-Life Management

Management should plan for a system's life cycle, eventual end of life, and any corresponding security and business impacts. The institution's strategy should incorporate planned changes to systems, including an evaluation of the current environment to identify potential vulnerabilities, upgrade opportunities, or new defense layers. Also included in this strategy should be considerations for the support provided by third-party system vendors and the risks related to operating unsupported legacy systems. Management should have policies to manage both the hardware and software life cycles. Security risks related to reaching a system's end of life include (a) the increased potential for vulnerabilities because the third party no longer provides patches or support, (b) incompatibility with other systems in the institution's environment, and (c) limitations in security features in older or obsolete systems.

Effective end-of-life management should include the following:

- Maintaining inventories of systems and applications.
- Adhering to an approved end-of-life or sunset policy for older systems.
- Tracking changes made to the systems and applications, availability of updates, and the planned end of support by the vendor.
- Conducting risk assessments on systems and applications to help determine end-of-life.
- Planning for the replacement of systems nearing obsolescence and complying with policy requirements for implementing new systems or applications.
- Developing specific procedures for the secure destruction or data wiping of hard drives returned to vendors or donated, to prevent the inadvertent disclosure of sensitive information.

If an end-of-life system or application must remain in use, management should ensure appropriate mitigating controls are in place, which may include segregating the system or application from the network. Management should also have a plan to replace the system or application and implement compensating controls until replacement. Strategies for replacing and updating hardware and software should incorporate and align with overall information security and business strategies as appropriate.

II.C.12 Malware Mitigation

Attackers use malware to obtain access to an institution's environment and to execute an attack within the environment. Malware may enter through public or private networks and from devices

attached to the network. Although protective mechanisms may block most malware before it does damage, even a single malicious executable³⁴ may create a significant potential for loss.

Management should implement defense-in-depth to protect, detect, and respond to malware. The institution can use many tools to block malware before it enters the environment and to detect it and respond if it is not blocked. Methods or systems that management should consider include the following:

- Hardware-based roots of trust, which use cryptographic means to verify the integrity of software.
- Servers that run active content at the gateway and disallow content based on policy.
- Blacklists that disallow code execution based on code fragments, Internet locations, and other factors that correlate with malicious code.
- White lists of allowed programs.
- Port monitoring to identify unauthorized network connections.
- Network segregation.
- Computer configuration to permit the least amount of privileges necessary to perform the user's job.
- Application sandboxing³⁵ to limit the access and functionality of executed code.
- Monitoring for unauthorized software and disallowing the ability to install unauthorized software.
- Monitoring for anomalous activity for malware and polymorphic code.
- Monitoring of network traffic.
- User education in awareness, safe computing practices, indicators of malicious code, and response actions.

II.C.13 Control of Information

Action Summary

Management should control and protect access to and transmission of information to avoid loss or damage and do the following:

- Establish and supervise compliance with policies for storing and handling information, including storing data on mobile devices and cloud services.
- Define and implement appropriate controls over the electronic transmission of information.
- Facilitate safe and secure disposal of sensitive information.
- Secure physical media in transit.

³⁴ In computing, an executable is a file or a program that is able to be run by a computer.

³⁵ Sandboxing is the use of a restricted, controlled execution environment that prevents potentially malicious software, such as mobile code, from accessing any system resources except those for which the software is authorized.

II.C.13(a) *Storage*

Management should implement policies to govern the secure storage of all types of sensitive information, whether on computer systems, on physical media, or in hard-copy documents. Management can achieve secure storage with physical controls,³⁶ logical controls (e.g., passwords, tokens, and biometrics), and environmental controls (e.g., fire and flood protection). In addition, stored information, in any form, should be classified and inventoried so that it can be retrieved when needed. Inventories should be updated periodically to remain current.

More sensitive information, such as system documentation, application source code, and production transaction data, should have more extensive controls to guard against alteration (e.g., integrity checkers and cryptographic hashes). Management should have appropriate logging and monitoring controls over stored information to ensure authorized access and appropriate use. Periodically, the security staff, audit staff, and data owners should review access rights to ensure the access rights remain appropriate and current.

Data storage in portable devices, such as laptops, smart phones, and tablets, poses unique problems. These devices may be lost, stolen, or subject to unauthorized and undetected use. Risk mitigation typically involves data encryption, host-provided access controls, homing beacons,³⁷ and remote deletion³⁸ capabilities. Management should implement appropriate controls (such as the use of a DLP program) over portable devices and the sensitive information contained on them.

Many institutions create or use a third-party cloud for storage. Cloud storage³⁹ provides unique issues and challenges. Management should understand the nature of the cloud technology being used; the physical location(s) where the data are stored and related legal jurisdiction; the access controls used and protection of the institution's data (e.g., how access is controlled and how that information is retrieved); and the frequency and method of backup used by the cloud provider. Management should verify that the cloud provider offers the capability for the institution to monitor its system activity, significant security incidents, performance and uptime, and success and failure of backups.

II.C.13(b) *Electronic Transmission of Information*

Electronic transmission of information can include e-mail, file transfer protocol (FTP), secure FTP (sFTP), secure shell, dedicated line, short message service/texting, and transmission via the Internet. Management should determine the type of transmission method, sensitivity of the

³⁶ Refer to the "Physical Security" section of this booklet.

³⁷ Homing beacons send messages to the institution when they connect to a network and enable recovery of the device.

³⁸ Remote deletion is a technology that enables the institution to remotely delete certain data from a portable device.

³⁹ Cloud storage is a model of data storage in which the digital data are stored in logical pools, the physical storage spans multiple servers (and often locations), and the physical environment is typically owned and managed by a hosting company.